

GALILEOTECHSOLUTIONS

Plan Director de Seguridad de la Información y Ciberseguridad

Gobierno · Riesgo · Protección · Concienciación · Auditoría · Resiliencia

Documento corporativo

Versión 1.1 · 07/10/2026 · Clasificación: USO INTERNO

Propietario: Responsable de Seguridad / CISO · Aprobación: Dirección General

Caso profesional ficticio para GalileoTechSolutions

Este plan está diseñado con nivel de madurez objetivo alto y debe adaptarse, validarse jurídica y técnicamente antes de utilizarse en una organización real.

Control del documento

Campo	Valor
Título	Plan Director de Seguridad de la Información y Ciberseguridad
Organización	GalileoTechSolutions
Versión	1.1
Fecha de aprobación	07/10/2026
Entrada en vigor	14/10/2026
Próxima revisión ordinaria	07/10/2027
Propietario	CISO / Responsable de Seguridad
Aprobador	Dirección General
Clasificación	Uso interno
Ciclo de revisión	Anual y extraordinario ante cambios o incidentes relevantes

Histórico de cambios

Versión	Fecha	Cambio	Autor / propietario
1.0	06/10/2026	Emisión inicial del Plan Director	CISO / Comité de Seguridad
1.1	07/10/2026	Incorporación de arquitectura IDS/IPS/SIEM/SOC en el ciclo de seguridad y diccionario corporativo de siglas.	CISO / Comité de Seguridad

Aprobación formal

Rol	Nombre	Decisión	Fecha / firma
Dirección General	_____	Aprobado / Rechazado	_____
CISO / Responsable de Seguridad	_____	Propone	_____
DPO / Legal	_____	Revisado	_____
IT / Operaciones	_____	Viabilidad técnica	_____

Mapa del Plan

- 1. Resumen ejecutivo
- 2. Perfil de GalileoTechSolutions y supuestos del caso
- 3. Objetivos, alcance y exclusiones
- 4. Marco de referencia y obligaciones
- 5. Principios de seguridad
- 6. Gobierno, organización y responsabilidades
- 7. Inventario, propiedad y clasificación de activos
- 8. Gestión de riesgos y priorización
- 9. Arquitectura de políticas y normas
- 10. Identidad y control de acceso
- 11. Protección del puesto de trabajo
- 12. Red, acceso remoto y servicios cloud
- 13. Desarrollo seguro y cadena de suministro de software
- 14. Gestión de vulnerabilidades, parchado y hardening
- 15. Arquitectura de monitorización, detección y respuesta
- 16. Protección de datos, backup y continuidad
- 17. Gestión de proveedores y terceros
- 18. Plan de concienciación y cultura
- 19. Auditoría, evidencias y aseguramiento
- 20. Cuadro de mando: KPI y KRI
- 21. Excepciones, incumplimientos y aceptación de riesgo

- 22. Simulacros y pruebas de resiliencia
- 23. Preparación para incidentes
- 24. Hoja de ruta de implantación
- 25. Revisión, mejora continua y vigencia
- Anexo H. Diccionario corporativo de siglas y abreviaturas
- Anexos operativos

1. Resumen ejecutivo

GalileoTechSolutions adopta este Plan Director como marco corporativo para gobernar y reducir el riesgo de ciberseguridad, proteger la información y los servicios esenciales, demostrar cumplimiento y mantener la resiliencia operativa. El Plan convierte los principios de seguridad en requisitos verificables, métricas, responsabilidades y evidencias.

Objetivo de madurez

La organización aspira a una postura de seguridad medible, automatizable y basada en riesgo: inventario confiable, identidad fuerte, mínimo privilegio, endpoints gestionados, exposición mínima, desarrollo seguro, terceros controlados, copias recuperables, cultura de reporte y auditoría continua.

La lógica de gestión es cíclica:

DEFINIR → PROTEGER → OBSERVAR → ANALIZAR → MEDIR → CORREGIR → VERIFICAR → MEJORAR

El Plan se sustenta en un modelo de gobierno y mejora continua basado en riesgo, combinando marcos de referencia internacionales y españoles con controles técnicos y organizativos. La estrategia integra gestión de activos, identidad, Zero Trust, seguridad cloud, DevSecOps, gestión de vulnerabilidades, monitorización y detección, continuidad, terceros, concienciación, auditoría y respuesta preparada ante incidentes.

2. Perfil de GalileoTechSolutions y supuestos del caso

A efectos de este Plan, GalileoTechSolutions se modela como una consultora tecnológica B2B española con 120 empleados, trabajo híbrido, desarrollo de software e integración de sistemas, servicios cloud, proveedores con acceso remoto y tratamiento de información comercial, técnica y personal.

Dimensión	Situación de referencia
Personas	120 empleados; perfiles de desarrollo, sistemas, administración, RRHH, comercial, dirección y soporte.
Trabajo	Modelo híbrido, acceso remoto y movilidad.
Tecnología	Portátiles corporativos, servidores internos, servicios cloud/SaaS, repositorios de código, CI/CD, VPN/ZTNA, directorio corporativo, EDR/XDR, sensores IDS/IPS, firewall/NGFW, WAF, SIEM centralizado y telemetría de seguridad.
Información	Datos de clientes, documentación contractual, código fuente, secretos técnicos, datos personales, información financiera y operativa.
Terceros	Proveedores de cloud, soporte, telecomunicaciones y software con distinto nivel de acceso.
Situación inicial	Se han observado contraseñas débiles, software sin actualizar, cuentas antiguas, permisos excesivos, equipos sin bloqueo automático y accesos de terceros sin revisión suficiente.

2.1. Activos esenciales

- Identidad corporativa y directorio/SSO.
- Datos y documentación de clientes.
- Código fuente, repositorios y canal CI/CD.
- Servicios productivos y portales de clientes.
- Copias de seguridad y capacidades de recuperación.
- Comunicaciones, acceso remoto y conectividad.
- ERP, finanzas, RRHH y colaboración.
- Conocimiento corporativo y propiedad intelectual.

3. Objetivos, alcance y exclusiones

3.1. Objetivos

- Proteger confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad.
- Reducir la probabilidad y el impacto de incidentes mediante controles técnicos y organizativos.
- Establecer una gobernanza clara, con responsabilidades, evidencias y criterios de decisión.
- Gestionar riesgos de forma trazable, desde el hallazgo técnico hasta la medida y el riesgo residual.
- Mantener una cultura de seguridad medible y orientada a comportamientos.
- Cumplir obligaciones legales, contractuales y de clientes aplicables.
- Preservar continuidad de negocio y capacidad de recuperación.

3.2. Alcance

El Plan se aplica a personal, directivos, becarios, personal temporal y terceros; a todos los activos de información, sistemas, cuentas, redes, dispositivos, servicios cloud, repositorios, datos y ubicaciones utilizadas para prestar servicios de GalileoTechSolutions, incluyendo teletrabajo y acceso remoto.

3.3. Exclusiones y no aplicabilidad

Cualquier exclusión debe documentarse como excepción formal, justificar el motivo, valorar el riesgo, definir controles compensatorios, responsable, fecha de caducidad y revisión. No se permiten exclusiones implícitas.

4. Marco de referencia y obligaciones

El Plan utiliza marcos complementarios. La aplicación legal concreta debe revisarse por Legal/DPO según actividad, clientes y jurisdicción.

Marco	Uso en GalileoTechSolutions
ISO/IEC 27001:2022	Referencia para el sistema de gestión, gobierno, mejora continua y tratamiento del riesgo.
ISO/IEC 27002:2022	Catálogo de buenas prácticas y controles de seguridad.
NIST Cybersecurity Framework 2.0	Estructura de madurez en seis funciones: Govern, Identify, Protect, Detect, Respond y Recover.
NIST SP 800-61 Rev. 3	Referencia para integrar preparación y respuesta a incidentes en la gestión global del riesgo.
MAGERIT v3	Metodología de análisis de riesgos y catálogo de amenazas; especialmente útil en contexto español.
ENS - RD 311/2022	Referencia obligatoria cuando sea aplicable por relación con sistemas/servicios del sector público; benchmark de seguridad por riesgos.
RGPD / LOPDGDD	Protección de datos personales, privacidad por diseño y obligaciones asociadas.
NIS2 / transposición nacional aplicable	Aplicable solo si la entidad/servicios entran en el ámbito; se adopta como benchmark de gobierno y resiliencia.
ISO 22301:2019	Continuidad de negocio y prueba periódica de capacidades de recuperación.
ENISA Threat Landscape	Contexto de amenazas, vectores y tendencias; no se usa como equivalencia 1:1 con MAGERIT.
MITRE ATT&CK Enterprise	Modelado del comportamiento adversario mediante tácticas y técnicas.
OWASP ASVS / SAMM	Referencia para seguridad de aplicaciones y madurez de desarrollo seguro.

Criterio de uso

MAGERIT expresa la amenaza y el riesgo sobre activos; MITRE ATT&CK describe el comportamiento del adversario; ENISA aporta contexto externo y tendencias; OpenVAS/Greenbone y otras herramientas aportan evidencias técnicas. Ninguna herramienta sustituye el juicio de riesgo.

Regla de lectura corporativa

Las siglas se desarrollan en su primera aparición cuando resulta práctico y se recogen de forma consolidada en el Anexo H. El diccionario forma parte del Plan y debe consultarse cuando el documento se distribuya a personal no especializado.

5. Principios de seguridad

Principio	Aplicación
Riesgo y proporcionalidad	Las medidas se priorizan por riesgo, criticidad del activo, exposición y obligaciones.
Mínimo privilegio	Los usuarios y servicios reciben solo los permisos necesarios y por el tiempo necesario.
Zero Trust	No se confía por defecto en usuario, dispositivo, red o ubicación; se verifica identidad, postura y contexto.
Defensa en profundidad	Se combinan controles preventivos, detectivos, correctivos y de recuperación.
Seguridad por diseño y por defecto	Proyectos, aplicaciones, cloud y cambios incorporan seguridad desde el inicio.
Trazabilidad	Las decisiones y acciones relevantes deben quedar registradas y ser auditables.
Necesidad de conocer	El acceso a información se limita a quien lo necesita para su función.
Recuperabilidad	Todo servicio crítico debe tener estrategia de backup, restauración y continuidad probada.
Responsabilidad compartida	Dirección, seguridad, IT, desarrollo, usuarios y terceros tienen obligaciones diferenciadas.
Mejora continua	Métricas, auditorías, simulacros e incidentes alimentan nuevas versiones del Plan.

6. Gobierno, organización y responsabilidades

6.1. Estructura de gobierno

Rol	Responsabilidad
Dirección General	Aprueba la política y el apetito de riesgo, asigna recursos y acepta riesgos críticos cuando proceda.
Comité de Seguridad	Revisa riesgos, KPI/KRI, excepciones, auditorías, incidentes relevantes y hoja de ruta. Reunión trimestral.
CISO (Chief Information Security Officer) / Responsable de Seguridad	Propietario del Plan; coordina riesgo, políticas, auditoría, concienciación, terceros y mejora.
IT / Sistemas	Opera infraestructura, identidades, endpoints, red, parches, backup y controles técnicos.
DevSecOps / Ingeniería	Integra controles de seguridad en diseño, código, dependencias, CI/CD y despliegue.
DPO (Data Protection Officer) / Legal / Compliance	Evalúa privacidad, requisitos legales/contractuales y notificaciones.
RRHH	Integra seguridad en altas, cambios, bajas, formación y medidas disciplinarias.
Propietarios de activos/procesos	Valoran criticidad, aprueban requisitos y participan en aceptación del riesgo.
Usuarios	Cumplen normas, protegen credenciales y reportan anomalías.
Proveedores	Cumplen requisitos contractuales, evidencian controles y notifican incidentes que afecten al servicio.
SOC / Seguridad Operativa	Opera la monitorización continua, triaje de alertas, correlación SIEM, gestión de casos de uso, tuning y escalado técnico al CISO/IT.

6.2. Matriz RACI corporativa

Actividad	Dirección	CISO	IT	Dev	DPO/Legal	Usuarios/Terceros
Aprobar Plan y apetito de riesgo	A	R	C	C	C	I
Mantener políticas	I	R/A	C	C	C	I
Inventario y clasificación	I	A	R	R	C	I
Gestión de vulnerabilidades	I	A	R	R	C	I
Parcheado/hardening	I	C/A	R	R	I	I
Alta/baja de accesos	I	A	R	C	C	I
Revisión de proveedores críticos	I	A/R	C	C	C	I
Concienciación	I	A/R	C	C	C	R
Auditoría interna	I	A/R	C	C	C	I
Aceptar riesgo crítico	A	R	C	C	C	I
Autorizar excepción de alto riesgo	A	R	C	C	C	I

6.3. Responsabilidades operativas de detección

La operación de sensores y del SIEM requiere responsabilidades explícitas para evitar alertas sin propietario, reglas sin mantenimiento o fuentes de datos desconectadas.

Actividad	SOC	CISO	IT / Sistemas	DevSecOps / Aplicaciones
Supervisar salud de sensores y fuentes	R	A	C	C
Triaje de alertas SIEM	R	A	C	I
Tuning de reglas y reducción de falsos positivos	R	A	C	C
Cambio de IDS a IPS inline	C	A	R	C
Alta de nuevas fuentes de logs	R	A	R	R
Prueba de casos de uso MITRE ATT&CK	R	A	C	C
Escalado de alerta crítica	R	A	R	C

7. Inventario, propiedad y clasificación de activos

No se puede proteger ni auditar lo que no está identificado. GalileoTechSolutions mantendrá un inventario/CMDB con propietario, criticidad, ubicación, dependencias, estado de soporte y clasificación de información.

Clase de información	Descripción	Ejemplos	Requisito mínimo
Pública	Divulgación autorizada	Web, notas de prensa	Integridad y aprobación de publicación.
Interna	Uso corporativo; impacto limitado si se divulga	Procedimientos, documentación interna	Acceso corporativo autenticado.
Confidencial	Impacto relevante comercial, contractual o personal	Contratos, datos de clientes, finanzas	Cifrado, acceso por necesidad, registro.
Restringida	Impacto grave o crítico	Secretos, credenciales, claves, datos sensibles, código crítico	MFA fuerte, mínimo privilegio, cifrado, DLP/controles reforzados, revisión periódica.

7.1. Reglas de inventario

- Todo activo productivo debe tener propietario y criticidad.
- Todo software debe tener responsable, versión soportada y proceso de actualización.
- Toda cuenta privilegiada debe estar inventariada y revisarse al menos trimestralmente.
- Los servicios expuestos a Internet deben estar registrados, justificados y monitorizados.
- Los repositorios y pipelines deben tener propietarios y protección de ramas, secretos y artefactos.
- Los activos sin propietario o sin soporte se consideran hallazgo de seguridad.

8. Gestión de riesgos y priorización

El proceso corporativo conecta evidencia técnica y contexto empresarial. CVSS indica gravedad técnica, pero no equivale al riesgo de GalileoTechSolutions.

Cadena de trazabilidad

HALLAZGO → CAPACIDAD TÉCNICA → ACTIVO → CONSECUENCIA → AMENAZA MAGERIT → COMPORTAMIENTO MITRE → IMPACTO/PROBABILIDAD → RIESGO → MEDIDA → RIESGO RESIDUAL

8.1. Fuentes de evidencia

- Inventario/CMDB y MDM/EDR.
- Auditoría local autorizada; WinAudit puede emplearse como fuente de corroboración puntual.
- Greenbone/OpenVAS para exposición y vulnerabilidades conocidas.
- Configuraciones cloud, IAM, repositorios, CI/CD y ticketing.
- Logs/SIEM, entrevistas, observación y documentos de proceso.
- NVD y fuentes del fabricante para verificar CVE.

8.2. Escala operativa de riesgo 5x5

Para priorización operativa se utiliza $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$. Es una escala corporativa simplificada compatible con la lógica de gestión por riesgos; los análisis formales MAGERIT pueden utilizar valoraciones más completas.

Valor	Impacto	Probabilidad
1	Insignificante	Muy improbable
2	Bajo	Poco probable
3	Medio	Posible
4	Alto	Probable
5	Muy alto / crítico	Muy probable

Resultado	Nivel	Tratamiento
1-4	Bajo	Planificar o aceptar justificadamente.
5-9	Medio	Tratar de forma programada y monitorizar.
10-16	Alto	Prioridad alta; plan de reducción con plazo.
17-25	Crítico	Actuación prioritaria; no se acepta sin decisión ejecutiva formal y plazo.

8.3. Matriz 5x5

P\I	1	2	3	4	5
1	1 Bajo	2 Bajo	3 Bajo	4 Bajo	5 Medio
2	2 Bajo	4 Bajo	6 Medio	8 Medio	10 Alto
3	3 Bajo	6 Medio	9 Medio	12 Alto	15 Alto
4	4 Bajo	8 Medio	12 Alto	16 Alto	20 Crítico
5	5 Medio	10 Alto	15 Alto	20 Crítico	25 Crítico

8.4. Registro inicial de riesgos del caso

ID	Escenario	I	P	Riesgo	Tratamiento inicial
R-01	Credenciales predeterminadas o débiles en acceso remoto	5	5	25 Crítico	Eliminar credenciales por defecto; MFA; claves; restricción de origen.
R-02	Servicio crítico vulnerable/expuesto sin autenticación	5	4	20 Crítico	Parchear/deshabilitar; segmentar; reducir exposición; reescaneo.
R-03	Software sin actualizar en endpoints	4	4	16 Alto	Gestión centralizada de parches; SLA y excepciones.
R-04	Cuentas antiguas o huérfanas	4	4	16 Alto	Recertificación; baja automática; revisión trimestral.
R-05	Permisos excesivos / privilegios permanentes	5	3	15 Alto	RBAC, JIT/PAM, mínimo privilegio.
R-06	Accesos de proveedores no revisados	5	3	15 Alto	Inventario, caducidad, MFA, revisión trimestral, logs.
R-07	Equipos sin bloqueo automático	3	3	9 Medio	Baseline MDM/GPO; bloqueo ≤10 min.
R-08	Software no autorizado / shadow IT	4	3	12 Alto	Catálogo, allow-list, proceso de solicitud, formación.

9. Arquitectura de políticas y normas

El Plan Director establece el marco. Debajo se mantienen políticas y estándares más específicos, procedimientos operativos y registros de evidencia.

Nivel	Documento	Aprobación
1	Plan Director / Política General de Seguridad	Dirección General
2	Políticas: acceso, datos, puesto, cloud, terceros, desarrollo, backup, registro, teletrabajo/BYOD	CISO + responsable de negocio
3	Estándares técnicos: hardening, cifrado, logging, parcheado, IAM, CI/CD	CISO / IT / DevSecOps
4	Procedimientos y playbooks	Responsable operativo
5	Registros: tickets, evidencias, actas, excepciones, métricas y auditorías	Propietario del proceso

9.1. Ciclo de vida documental

NECESIDAD → REDACCIÓN → REVISIÓN → APROBACIÓN → COMUNICACIÓN → IMPLANTACIÓN → MEDICIÓN → AUDITORÍA → REVISIÓN

10. Identidad y control de acceso

- Identidades nominativas; prohibidas las cuentas compartidas salvo excepción técnica documentada.
- SSO corporativo y MFA obligatorio para acceso remoto, cloud, privilegios y aplicaciones críticas.
- Para administradores y roles de alto impacto se prioriza MFA resistente a phishing (FIDO2/passkeys o equivalente).
- RBAC y mínimo privilegio; elevación temporal/JIT para tareas administrativas cuando sea viable.
- Proceso joiner-mover-leaver coordinado con RRHH; bajas efectivas el mismo día de salida.
- Recertificación trimestral de privilegios y accesos de terceros; semestral del resto de accesos sensibles.
- Credenciales y secretos técnicos almacenados en gestor de secretos; prohibido incluirlos en código o documentación sin protección.
- Cuentas de servicio con propietario, finalidad, rotación y monitorización.
- Bloqueo y detección de intentos anómalos; registro centralizado de autenticaciones.

Objetivo medible

100 % de cuentas privilegiadas con MFA; 0 cuentas huérfanas críticas; 100 % de accesos de terceros revisados trimestralmente.

11. Protección del puesto de trabajo

La baseline del puesto traduce la política en condiciones verificables. Cada control debe indicar requisito, evidencia, estado y acción correctiva.

ID	Control obligatorio
PST-01	Cuenta individual corporativa; sin cuentas locales no justificadas.
PST-02	MFA activo cuando corresponda.
PST-03	Usuario estándar sin privilegios administrativos permanentes.
PST-04	Bloqueo automático de pantalla en ≤ 10 minutos y bloqueo manual al ausentarse.
PST-05	Sistema operativo soportado y parcheado.
PST-06	EDR/antimalware activo, actualizado y protegido contra manipulación.
PST-07	Firewall local activo con política corporativa.
PST-08	Cifrado completo de disco en portátiles y dispositivos móviles corporativos.
PST-09	Solo software autorizado y necesario; inventario actualizado.
PST-10	Servicios y tareas de arranque innecesarios deshabilitados.
PST-11	Navegador y extensiones gestionados; protección web/DNS corporativa.
PST-12	USB y soportes extraíbles restringidos o controlados según riesgo.
PST-13	Datos corporativos almacenados solo en ubicaciones autorizadas y sincronizadas/protegidas.
PST-14	Acceso remoto solo desde dispositivo gestionado y canal aprobado.
PST-15	Logs relevantes y telemetría de endpoint enviados al sistema central.
PST-16	Sin secretos en texto claro en escritorio, scripts o ficheros de usuario.
PST-17	Actualizaciones de aplicaciones críticas gestionadas centralmente.
PST-18	Configuración de hora sincronizada.
PST-19	Uso de pantalla limpia y custodia física del equipo.
PST-20	Borrado seguro y retirada controlada al final de vida.

La evidencia primaria procede de MDM/EDR/gestión de configuración e inventario central. WinAudit u otras herramientas locales se reservan para corroboraciones, muestreos o investigación de discrepancias; la ausencia de un dato en una herramienta no demuestra por sí misma incumplimiento.

12. Red, acceso remoto y servicios cloud

- Segmentación por función y criticidad; redes de administración separadas de usuarios y producción.
- Política de deny-by-default en perímetros y exposición mínima de servicios.
- Toda exposición a Internet debe tener propietario, justificación, inventario, TLS y monitorización.
- Acceso remoto mediante ZTNA/VPN corporativa con MFA y dispositivo gestionado; se evita acceso directo de administración desde Internet.
- Revisión continua de grupos de seguridad, firewalls, rutas, identidades y recursos públicos en cloud.
- Logs de control plane y acceso a recursos cloud centralizados en SIEM.
- Cifrado en tránsito con protocolos vigentes; deshabilitación de protocolos obsoletos.
- DNS seguro, protección de correo y controles anti-phishing (SPF, DKIM, DMARC en modo adecuado).
- Arquitectura cloud con cuentas/proyectos separados por entorno y mínimo privilegio.
- Configuración declarativa e Infrastructure as Code revisada y versionada cuando sea viable.

- Los perímetros, DMZ y segmentos críticos dispondrán de sensores Suricata en modo IDS; los puntos de control previamente validados podrán operar en modo IPS inline para bloquear tráfico malicioso con cambio controlado y procedimiento de reversión.
- Los eventos de NGFW, WAF, IDS/IPS, VPN/ZTNA, DNS, correo y servicios cloud se enviarán al SIEM corporativo para correlación y trazabilidad.

13. Desarrollo seguro y cadena de suministro de software

Como empresa tecnológica, la seguridad del software es un control esencial. El ciclo de desarrollo debe integrar seguridad desde requisitos hasta operación.

Fase	Control mínimo
Requisitos	Clasificación de datos, requisitos de seguridad y abuso/casos de amenaza para funcionalidades críticas.
Diseño	Threat modeling en sistemas críticos y revisión de arquitectura.
Código	Revisión por pares, SAST, detección de secretos y reglas de codificación segura.
Dependencias	SCA/dependency scanning, inventario de componentes y gestión de vulnerabilidades; SBOM para productos críticos cuando proceda.
CI/CD	Pipelines protegidos, separación de funciones, artefactos firmados cuando sea viable, secretos fuera del repositorio.
Pruebas	DAST/API testing para aplicaciones expuestas y pruebas de seguridad antes de releases de alto riesgo.
Despliegue	Cambios aprobados, rollback, configuración segura, segregación de entornos.
Operación	Monitorización, gestión de vulnerabilidades, respuesta y aprendizaje de defectos de seguridad.

Regla de entrega

No se despliega una versión con vulnerabilidad crítica conocida sin tratamiento aprobado, controles compensatorios y aceptación formal del riesgo.

14. Gestión de vulnerabilidades, parcheado y hardening

La gestión de vulnerabilidades es continua: descubrir, validar, contextualizar, priorizar, tratar, verificar y medir.

Severidad / condición	SLA objetivo máximo
Explotación activa o vulnerabilidad crítica expuesta a Internet	72 horas
Crítica no expuesta / sin explotación activa conocida	7 días
Alta	14 días
Media	30 días
Baja	90 días o siguiente ciclo planificado

Los SLA son objetivos corporativos y pueden ajustarse por contexto. Si no pueden cumplirse, debe abrirse excepción con controles compensatorios y fecha de cierre.

- Escaneo autenticado mensual de redes internas críticas y después de cambios relevantes.
- Superficie externa e Internet revisada al menos semanalmente mediante herramientas automatizadas.
- Validación de hallazgos críticos antes de escalar; los falsos positivos se documentan.
- OpenVAS/Greenbone se usa para vulnerabilidades y exposición; no para declarar por sí solo un incidente.
- Se integra información de CVE/fabricante y, cuando proceda, evidencia de explotación activa.
- Todo cierre crítico requiere reescaneo o evidencia técnica equivalente.
- Pentest independiente anual y después de cambios relevantes en activos críticos.

15. Arquitectura de monitorización, detección y respuesta

- Centralizar logs de identidad, endpoint, servidores, red, cloud, aplicaciones críticas y herramientas de seguridad.
- Sincronización horaria consistente para soportar trazabilidad.
- Protección de registros frente a modificación y borrado no autorizado.
- Reglas de detección alineadas con activos críticos y escenarios de riesgo; MITRE ATT&CK se emplea como lenguaje de comportamiento, no como puntuación de riesgo.
- Revisión periódica de cobertura de logs y casos de uso; eliminar ruido mediante tuning documentado.
- Alertas críticas con responsable, canal de escalado y prueba periódica de funcionamiento.
- Retención definida por necesidades legales, contractuales, forenses y operativas.

KPI asociado

Cobertura de logging en activos críticos $\geq 98\%$; fuentes críticas sin datos $>24\text{ h} = 0$.

15.1. Arquitectura de referencia

GalileoTechSolutions adopta una arquitectura de detección por capas. El objetivo es convertir eventos técnicos en señales contextualizadas y accionables, manteniendo trazabilidad desde el sensor hasta la decisión operativa.

Cadena operativa

FUENTES DE TELEMETRÍA → IDS/IPS / EDR-XDR / CONTROLES CLOUD → SIEM → SOC → ALERTA → ANÁLISIS → CONTENCIÓN / CORRECCIÓN → LECCIONES APRENDIDAS

Capa	Tecnología de referencia	Función principal	Destino / integración
Perímetro y DMZ	Suricata NIDS/NIPS + NGFW + WAF	Inspección de tráfico, detección de firmas/anomalías y bloqueo selectivo.	Eventos y alertas al SIEM.
Segmentación interna	Suricata IDS y controles de red	Visibilidad este-oeste y detección de reconocimiento, explotación y movimiento lateral.	SIEM + SOC.
Endpoints Windows	EDR/XDR + Sysmon + agente Wazuh	Telemetría de procesos, autenticación, persistencia, cambios y actividad sospechosa.	SIEM Wazuh.
Servidores Linux	EDR/XDR cuando proceda + auditd + agente Wazuh	Eventos de sistema, autenticación, integridad y actividad administrativa.	SIEM Wazuh.
Cloud/SaaS	Logs nativos de identidad, control plane, acceso y seguridad	Visibilidad de cambios, autenticaciones, recursos públicos y actividad de API.	SIEM Wazuh / conectores.
Identidad	Directorio, SSO, MFA, PAM/IAM	Detección de accesos anómalos, abuso de privilegios y cambios sensibles.	SIEM + casos de uso de identidad.
Correlación	Wazuh SIEM/XDR	Normalización, correlación, reglas, enriquecimiento, alertado y retención.	SOC y ticketing.

15.2. IDS e IPS de red

Suricata es el motor de referencia para Network Intrusion Detection System (NIDS) y Network Intrusion Prevention System (NIPS). En modo IDS observa y alerta sin bloquear; en modo IPS trabaja inline y puede descartar tráfico conforme a reglas aprobadas.

- Modo por defecto en nuevos despliegues: IDS hasta completar línea base, tuning y validación de impacto.
- Paso a IPS: solo en puntos definidos, con aprobación de cambio, pruebas, métricas de falsos positivos y rollback documentado.
- Cobertura prioritaria: Internet/DMZ, accesos remotos, segmentos de administración, redes de servidores críticos y enlaces entre zonas de distinta confianza.
- Las reglas deben mantenerse actualizadas, versionadas y asociadas a un propietario; las excepciones de firma requieren justificación y caducidad.
- Una alerta IDS/IPS no se considera incidente por sí sola: debe correlacionarse con contexto, activo, identidad, telemetría de endpoint y otras evidencias.

15.3. SIEM y operación SOC

Wazuh constituye la plataforma SIEM/XDR de referencia del Plan. Debe centralizar eventos relevantes, preservar su integridad, aplicar reglas de correlación y proporcionar al SOC una cola priorizada de alertas. La arquitectura podrá evolucionar o sustituirse siempre que mantenga las capacidades y evidencias exigidas por este Plan.

- Fuentes mínimas: identidad, autenticación, EDR/XDR, Sysmon, auditd, Windows Event Logs, firewall/NGFW, WAF, Suricata, VPN/ZTNA, DNS, correo, cloud, aplicaciones críticas, bases de datos y plataformas DevSecOps.
- Las fuentes críticas se monitorizan también por salud: una pérdida de telemetría superior a 24 horas genera alerta operativa.
- Las reglas SIEM se versionan, prueban y revisan; cada caso de uso debe indicar fuente, lógica, severidad, propietario, respuesta esperada y técnica MITRE ATT&CK asociada cuando proceda.
- Las alertas críticas deben generar ticket/caso, propietario y marca temporal; no se admite cierre sin justificación y evidencia.
- El tuning se documenta para reducir ruido sin silenciar comportamientos de riesgo.

15.4. Casos de uso de detección prioritarios

Escenario / señal	Fuentes principales	MITRE ATT&CK orientativo	Respuesta inicial
-------------------	---------------------	--------------------------	-------------------

Escenario / señal	Fuentes principales	MITRE ATT&CK orientativo	Respuesta inicial
Fuerza bruta o password spraying	IAM/SSO, VPN, AD, Wazuh	T1110 - Brute Force	Correlacionar origen/usuario, bloquear o limitar, revisar compromiso.
Uso de cuenta predeterminada o anómala	IAM/AD, SSH, Wazuh	T1078.001 - Default Accounts	Deshabilitar/cambiar credenciales, revisar actividad y alcance.
Explotación de servicio público	Suricata, WAF, NGFW, logs de aplicación	T1190 - Exploit Public-Facing Application	Validar explotación, contener servicio/origen y revisar activo.
Escaneo de servicios / reconocimiento	Suricata/NDR, firewall	T1046 - Network Service Discovery	Validar legitimidad, bloquear si procede y revisar origen.
PowerShell o scripting sospechoso	EDR/XDR, Sysmon, Wazuh	T1059.001 - PowerShell	Aislar si procede, analizar árbol de procesos y credenciales.
Manipulación o desactivación de defensas	EDR/XDR, Wazuh, logs de administración	T1562 - Impair Defenses	Escalado crítico, restaurar control y analizar compromiso.

15.5. Criterios de diseño y retención

- La monitorización se diseña según criticidad del activo y escenario de riesgo, no por acumulación indiscriminada de logs.
- Los relojes de sistemas y sensores se sincronizan para preservar secuencia temporal y trazabilidad.
- Los registros críticos se protegen contra borrado o modificación por administradores ordinarios.
- La retención se define por obligaciones legales/contractuales, necesidades forenses, coste y valor operativo; los periodos se documentan por fuente.
- El acceso al SIEM sigue mínimo privilegio y MFA; las acciones administrativas sobre reglas, índices y retención quedan auditadas.

16. Protección de datos, backup y continuidad

16.1. Protección de información

- Cifrado en tránsito y en reposo para información confidencial/restringida cuando el entorno lo permita.
- Minimización de datos personales y privacidad por diseño en nuevos procesos.
- DLP o controles equivalentes en canales de alto riesgo según criticidad.
- Retención y destrucción segura conforme a necesidad legal/contractual.
- Compartición externa con autorización, caducidad y mínimo privilegio.

16.2. Backup

- Estrategia 3-2-1-1-0 para activos críticos cuando sea viable: 3 copias, 2 soportes, 1 fuera de ubicación, 1 inmutable/offline, 0 errores verificados.
- Backups cifrados, monitorizados y separados de identidades administrativas ordinarias.
- Pruebas de restauración mensuales para sistemas críticos y trimestrales para el resto de servicios relevantes.
- Resultado de cada prueba registrado con tiempo real de recuperación, integridad y desviaciones.

16.3. Objetivos de continuidad

Servicio	Criticidad	RTO objetivo	RPO objetivo
Identidad / SSO	Crítica	2 h	15 min
Servicios productivos de clientes	Crítica	2-4 h según SLA	15-60 min
Repositorios y CI/CD	Alta	4 h	1 h
Colaboración y ficheros corporativos	Alta	4 h	4 h
ERP / Finanzas / RRHH	Alta	8 h	4 h
Servicios auxiliares	Media	24 h	24 h

Prueba, no declaración

Una copia de seguridad no se considera control efectivo hasta que la restauración se ha probado y el resultado queda registrado.

17. Gestión de proveedores y terceros

Los terceros se clasifican por criticidad según datos, acceso, dependencia y capacidad de impacto. La seguridad se incorpora al ciclo de compra y contrato.

- Due diligence de seguridad antes de contratar proveedores críticos.
- Requisitos contractuales de seguridad, confidencialidad, subcontratación, notificación de incidentes y devolución/borrado de datos.
- MFA y accesos nominativos para terceros; accesos temporales por defecto y revisión trimestral.
- Prohibición de credenciales genéricas de proveedor salvo justificación formal.
- Revisión anual de proveedores críticos y tras cambios/incidentes relevantes.
- Plan de salida y revocación de accesos al finalizar el servicio.
- Inventario de dependencias críticas y alternativas/contingencias.

Objetivo

100 % de accesos de terceros críticos revisados trimestralmente; 0 accesos vencidos activos.

18. Plan de concienciación y cultura de seguridad

La concienciación se diseña a partir de riesgos y hallazgos reales. El objetivo no es “dar formación”, sino modificar conductas observables y medir el resultado.

Público	Riesgos prioritarios	Acciones
Todo el personal	Phishing, contraseñas, bloqueo, USB, reporte	Onboarding + microlecciones + simulaciones + recordatorios.
Desarrollo	Secretos, dependencias, código inseguro, cloud	Formación segura, laboratorios, revisión de errores recurrentes.
IT / Administradores	Privilegios, hardening, cambios, logging	Formación técnica y ejercicios de configuración.
Dirección	Riesgo, fraude CEO, decisiones y crisis	Tabletop ejecutivo semestral.
RRHH / Finanzas	BEC, datos personales, fraude, adjuntos	Casos dirigidos y simulaciones específicas.
Proveedores críticos	Acceso remoto, notificación, manejo de datos	Cláusulas + briefing + validación de controles.

18.1. Objetivos anuales

- ≥ 98 % de personal completa la formación obligatoria en plazo.
- ≥ 80 % de acierto en evaluación; quien no alcance el umbral realiza refuerzo.
- Tasa de clic en phishing simulado ≤ 5 % al cierre del ciclo anual.
- Tasa de reporte correcto de simulaciones ≥ 70 %.
- Reducir en ≥ 50 % la reincidencia de hallazgos conductuales priorizados.

18.2. Calendario orientativo

Mes	Acción	Indicador
Enero	Reinicio anual: política, canales y responsabilidades	Finalización / test
Marzo	Phishing/BEC + simulación	Click / reporte
Mayo	Software autorizado, USB y datos	Cuestionario / hallazgos
Julio	Teletrabajo, movilidad y protección física	Checklist / muestreo
Septiembre	Contraseñas, MFA y secretos	MFA / pruebas
Noviembre	Ransomware, backup y reporte temprano	Tabletop / encuesta / reporte

18.3. Materiales

Se utilizarán infografías, fichas de una página, microlecciones, cuestionarios, casos, correos internos y checklists. Cada material debe tener público, riesgo, conducta esperada, propietario, versión, fecha de revisión e indicador. Se aplicarán criterios de accesibilidad y licencias de uso adecuadas.

19. Auditoría, evidencias y aseguramiento

La auditoría no consiste en buscar fallos de forma indiscriminada; contrasta requisitos aprobados con evidencias y produce acciones verificables.

Paso	Acción
1	Definir alcance: activos, usuarios, periodo y controles.
2	Establecer criterio: política, baseline, estándar o requisito contractual.
3	Recoger evidencia: CMDB/MDM/EDR, IAM, SIEM, alertas IDS/IPS, salud de sensores, WinAudit cuando proceda, OpenVAS, logs, documentos, entrevistas y observación.
4	Clasificar: cumple, no cumple, no aplica o evidencia insuficiente.
5	Valorar hallazgo: impacto, riesgo, repetición y causa.
6	Asignar acción correctiva: responsable, plazo y evidencia de cierre.
7	Verificar eficacia: reescaneo, revisión de configuración o nueva muestra.

19.1. Clasificación de hallazgos

Clase	Criterio orientativo
Crítico	Riesgo inmediato o control esencial inexistente; actuación urgente.
Mayor	Incumplimiento importante o repetido con impacto alto.
Menor	Desviación limitada sin impacto inmediato grave.
Observación	Oportunidad de mejora o evidencia aún no concluyente.

19.2. Programa de auditoría

- Revisión mensual de KPI y vulnerabilidades críticas.
- Muestreo trimestral de endpoints y accesos.
- Revisión trimestral de terceros críticos y cuentas privilegiadas.
- Auditoría interna anual del Plan completo.
- Auditoría externa / certificación cuando lo requiera negocio, cliente o estrategia.
- Seguimiento de acciones correctivas hasta evidencia de eficacia.

- La auditoría de controles detectivos verificará la cobertura real de telemetría, estado de sensores IDS/IPS, integración de fuentes SIEM, trazabilidad de alertas y evidencia de pruebas periódicas de casos de uso.
- Una regla SIEM o firma IDS/IPS no se considerará control eficaz solo por existir: debe demostrarse mediante prueba controlada, alerta generada, escalado esperado y revisión del resultado.

20. Cuadro de mando: KPI y KRI

Un KPI debe tener objetivo, fórmula, fuente, periodicidad, responsable, umbral y acción ante desviación. Un KRI indica exposición o riesgo creciente y puede requerir intervención aunque un KPI operativo sea correcto.

Indicador	Fórmula / medida	Periodicidad	Objetivo
Equipos actualizados	Actualizados / total $\times 100$	Mensual	$\geq 95 \%$
MFA privilegiado	Con MFA / cuentas privilegiadas $\times 100$	Mensual	100 %
MFA resistente a phishing en administradores	Admins con FIDO2/passkey / administradores $\times 100$	Mensual	$\geq 95 \%$
Críticas corregidas en SLA	Cerradas en SLA / detectadas $\times 100$	Mensual	$\geq 95 \%$
MTTR vulnerabilidades	Días totales / vulnerabilidades cerradas	Mensual	Tendencia decreciente
Backups verificados	Restauraciones correctas / pruebas $\times 100$	Mensual / trimestral	100 %
Accesos de terceros revisados	Revisados / total $\times 100$	Trimestral	100 %
Excepciones caducadas	Nº vencidas aún activas	Mensual	0
Formación completada	Completada / obligados $\times 100$	Trimestral	$\geq 98 \%$
Click phishing	Clicks / expuestos $\times 100$	Por campaña	$\leq 5 \%$
Reporte phishing	Reportes / expuestos $\times 100$	Por campaña	$\geq 70 \%$
Acciones correctivas en plazo	Cerradas en plazo / total $\times 100$	Mensual	$\geq 90 \%$
Cobertura logging crítica	Activos críticos con logs / total $\times 100$	Mensual	$\geq 98 \%$
Hallazgos repetidos	Nº de hallazgos reincidentes	Trimestral	Tendencia a 0
Cobertura SIEM de activos críticos	Activos críticos enviando telemetría / total $\times 100$	Mensual	$\geq 98 \%$
Fuentes críticas sin datos >24 h	Nº de fuentes críticas sin telemetría >24 h	Diaria / mensual	0
Cobertura IDS de segmentos críticos	Segmentos críticos monitorizados / total $\times 100$	Mensual	100 %
Puntos IPS validados	Puntos IPS operativos y probados / planificados $\times 100$	Trimestral	100 %
Alertas críticas atendidas en SLA	Alertas críticas dentro de SLA / total $\times 100$	Mensual	100 %
Casos de uso de detección probados	Casos probados con resultado esperado / planificados $\times 100$	Trimestral	$\geq 95 \%$
MTTD	Tiempo total hasta detección / incidentes confirmados	Trimestral	Tendencia decreciente
Disponibilidad del SIEM	Tiempo disponible / tiempo total $\times 100$	Mensual	$\geq 99,9 \%$

20.1. KRI principales

- Número de vulnerabilidades críticas abiertas fuera de SLA.
- Número de sistemas EOL/EOS.
- Número de cuentas privilegiadas permanentes sin revisión.
- Número de activos Internet sin propietario.
- Número de proveedores críticos sin evaluación vigente.
- Número de excepciones de alto riesgo abiertas.
- Número de restauraciones fallidas.
- Número de fuentes críticas de SIEM sin telemetría durante más de 24 horas.
- Número de segmentos críticos sin cobertura IDS.
- Número de alertas críticas no atendidas dentro del SLA.
- Número de firmas/reglas críticas deshabilitadas mediante excepción.

21. Excepciones, incumplimientos y aceptación de riesgo

21.1. Excepciones

Toda excepción debe ser previa, temporal, proporcional y trazable. No se aceptan excepciones “hasta nuevo aviso”.

Campo obligatorio	Contenido
Control / norma afectada	Referencia exacta
Motivo	Necesidad técnica o de negocio
Activo / servicio	Qué queda afectado
Riesgo	Impacto, probabilidad y nivel
Controles compensatorios	Qué reduce el riesgo mientras exista la excepción
Propietario	Responsable operativo
Aprobador	Según nivel de riesgo
Caducidad	Fecha concreta
Criterio de cierre	Qué evidencia permite cerrar la excepción

21.2. Autoridad de aceptación

Riesgo residual	Autoridad mínima
Bajo	Propietario del activo / proceso
Medio	CISO + propietario
Alto	CISO + Director del área
Crítico	Dirección General, con informe del CISO y plazo de reducción

21.3. Incumplimientos

Los incumplimientos se registran y se tratan según gravedad, impacto, intencionalidad y reincidencia. La respuesta prioriza la corrección y el aprendizaje, sin perjuicio de medidas disciplinarias cuando corresponda.

22. Simulacros y pruebas de resiliencia

Las políticas y planes deben probarse en “situaciones de paz”. Los ejercicios buscan fallos, zonas grises y dependencias ocultas antes de un incidente real.

Ejercicio	Frecuencia	Objetivo
Tabletop de gobierno y política	Semestral	Roles, decisiones, excepciones, comunicación y aprobación.
Prueba de restauración	Mensual crítico / trimestral resto	Verificar RTO/RPO e integridad de backup.
Simulación de phishing	Trimestral	Medir conducta y reporte; reforzar aprendizaje.
Tabletop de ransomware/continuidad	Anual	Coordinación ejecutiva, prioridades y recuperación.
Ejercicio de proveedor crítico	Anual	Validar dependencia, contactos y plan de contingencia.
Prueba técnica de controles de seguridad	Anual y tras cambios relevantes	Verificar exposición y eficacia.
Prueba de cadena IDS/IPS → SIEM → SOC	Trimestral y tras cambios relevantes	Generar tráfico/evento controlado y verificar sensor, ingestión, correlación, alerta, ticket, escalado y evidencia de cierre.

Todo ejercicio termina con un After Action Review: hechos, decisiones, brechas, acciones correctivas/preventivas (CAPA), responsable, plazo y verificación.

23. Preparación para incidentes

Este Plan no sustituye al Plan de Respuesta a Incidentes. Sí exige que exista y que esté alineado con la gobernanza, los activos y los riesgos aquí definidos.

- Canal claro de reporte para usuarios y terceros.
- Lista de contactos y suplencias actualizada.
- Criterios de severidad y escalado.
- Preservación de evidencias y registro cronológico.
- Capacidad de aislamiento de endpoints y credenciales.
- Canales de comunicación alternativos para crisis.
- Coordinación con Legal/DPO y obligaciones de notificación aplicables.
- Lecciones aprendidas integradas en políticas, controles y concienciación.
- Catálogo mantenido de casos de uso de detección y reglas SIEM alineadas con riesgos y MITRE ATT&CK.
- Capacidad operativa para aislar endpoints desde EDR/XDR y bloquear indicadores en IPS/NGFW/WAF bajo procedimiento aprobado.
- Disponibilidad de evidencias de red y host procedentes de IDS/IPS, SIEM y telemetría de endpoint para reconstruir la secuencia de un incidente.

Referencia actual

NIST SP 800-61 Rev. 3 (2025) integra la respuesta a incidentes dentro de la gestión global del riesgo y del NIST CSF 2.0.

24. Hoja de ruta de implantación

Horizonte	Prioridades
0-30 días	Aprobación del Plan; Comité de Seguridad; cierre de credenciales por defecto; MFA en administradores; inventario de terceros; revisión de vulnerabilidades críticas; prueba de backup crítica.
31-90 días	Baseline endpoint gestionada; proceso JML; recertificación de privilegios; SLA de vulnerabilidades; inventario de exposición Internet; programa de concienciación; cuadro de mando. Despliegue inicial de Wazuh SIEM/XDR; integración de identidad, endpoints y firewalls; piloto Suricata IDS en DMZ.
3-6 meses	EDR/MDM con cobertura objetivo; logging centralizado; revisión de cloud; due diligence de proveedores críticos; SSDLC con SAST/SCA/secret scanning; simulacro de política. Cobertura IDS en segmentos críticos; catálogo de casos de uso SIEM; pruebas trimestrales de detección; evaluación controlada de IPS inline.
6-12 meses	PAM/JIT para administradores; DLP selectivo; CSPM/continuous configuration; pentest independiente; pruebas de continuidad; madurez de evidencias automáticas. Activación IPS selectiva en puntos validados; madurez SOC, métricas MTTD y automatización de enriquecimiento/escalado.
12-24 meses	Zero Trust más granular; continuous control monitoring; SBOM y supply-chain assurance ampliados; preparación de certificación ISO/ENS si el negocio lo requiere.

25. Revisión, mejora continua y vigencia

El Plan se revisa al menos anualmente y de forma extraordinaria ante cambios significativos: nuevas tecnologías, fusiones, incidentes graves, nuevos proveedores críticos, cambios regulatorios, cambios de modelo de trabajo o auditorías con hallazgos relevantes.

- Las métricas y hallazgos alimentan el backlog de mejora.
- Las acciones correctivas tienen propietario y fecha.
- Un control no se considera implantado hasta disponer de evidencia.
- Un riesgo no se considera cerrado hasta reevaluar el riesgo residual.
- Los cambios en política se comunican y versionan.
- Las excepciones se cierran o renuevan antes de caducar; nunca se prorrogan de forma tácita.

Criterio de eficacia

El objetivo no es “tener documentos”, sino demostrar que la organización reduce exposición, corrige desviaciones, cambia comportamientos y recupera servicios dentro de objetivos.

Anexo A. Plantilla de registro de riesgos

ID	Activo	Escenario	Amenaza MAGERIT	MITRE	I	P	Riesgo	Medida	Residual	Propietario	Fecha

Anexo B. Plantilla de auditoría de cumplimiento

Control	Criterio	Evidencia	Resultado	Riesgo	Acción	Responsable	Plazo

Anexo C. Plantilla de KPI

KPI	Fórmula	Fuente	Periodicidad	Responsable	Objetivo	Resultado	Acción

Anexo D. Registro de excepción

Campo	Completar
Solicitante	
Norma/control afectado	
Justificación	
Activo/servicio	
Riesgo inherente	
Controles compensatorios	
Riesgo residual	
Propietario	
Aprobador	
Fecha inicio	
Caducidad	
Evidencia de cierre	

Anexo E. Acta de Comité de Seguridad

Campo	Contenido
Fecha	
Participantes	
Riesgos revisados	
KPIs/KRIs	

Campo	Contenido
Excepciones	
Hallazgos/auditorías	
Decisiones	
Acciones y responsables	
Próxima reunión	

Anexo F. Requisitos mínimos de una evidencia válida

- Identificar el requisito que se evalúa.
- Indicar fuente, fecha y alcance.
- Ser reproducible o verificable por un tercero autorizado.
- Distinguir dato observado de interpretación.
- Conservar integridad y control de acceso.
- Relacionar hallazgo con riesgo y acción correctiva.

Anexo G. Referencias normativas y metodológicas

El Plan se apoya en marcos y prácticas reconocidas de gobierno, gestión de riesgos, seguridad técnica, desarrollo seguro, concienciación, auditoría, resiliencia y mejora continua. Las referencias normativas y metodológicas se revisarán cuando cambien las obligaciones aplicables o los estándares adoptados.

La arquitectura y los controles de este Plan se seleccionan según el riesgo y la madurez objetivo de GalileoTechSolutions. Las tecnologías concretas podrán sustituirse por equivalentes siempre que mantengan las capacidades, trazabilidad, métricas y evidencias requeridas.

Referencia	Uso
ISO/IEC 27001:2022	SGSI, gobierno, riesgo y mejora continua.
ISO/IEC 27002:2022	Controles de seguridad.
NIST CSF 2.0	Gobierno y ciclo de gestión del riesgo.
NIST SP 800-61 Rev. 3 (2025)	Preparación y respuesta a incidentes integrada con CSF 2.0.
MAGERIT v3	Análisis de riesgos y catálogo de amenazas.
RD 311/2022 - ENS	Referencia española de seguridad basada en riesgos cuando aplique.
ISO 22301:2019	Continuidad de negocio.
MITRE ATT&CK Enterprise	Tácticas y técnicas adversarias.
ENISA Threat Landscape	Contexto de amenazas y tendencias.
OWASP ASVS / SAMM	Desarrollo seguro y madurez de software.

Anexo H. Diccionario corporativo de siglas y abreviaturas

Este diccionario facilita la lectura del Plan por personal técnico y no técnico. Cuando una sigla pueda tener varios significados, se recoge el utilizado específicamente en GalileoTechSolutions.

Sigla / abreviatura	Significado	Uso / explicación en GalileoTechSolutions
AD	Active Directory	Servicio de directorio utilizado para identidades, grupos, autenticación y políticas en entornos Microsoft.
API	Application Programming Interface	Interfaz que permite la comunicación programática entre aplicaciones o servicios.
ASVS	Application Security Verification Standard	Estándar OWASP para definir y verificar requisitos de seguridad de aplicaciones.
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge	Base de conocimiento de MITRE sobre tácticas y técnicas utilizadas por adversarios.
B2B	Business-to-Business	Modelo de negocio en el que la empresa presta servicios principalmente a otras organizaciones.
BEC	Business Email Compromise	Fraude basado en comprometer o suplantar correo corporativo para inducir pagos, cambios o divulgación de información.
BYOD	Bring Your Own Device	Uso de dispositivos personales para acceder a recursos corporativos bajo condiciones definidas.
CAPA	Corrective and Preventive Actions	Acciones correctivas y preventivas derivadas de auditorías, simulacros, incidentes o revisiones.
CEO	Chief Executive Officer	Máxima función ejecutiva; en el Plan aparece también en el contexto de fraude del CEO.
CI/CD	Continuous Integration / Continuous Delivery or Deployment	Automatización de integración, pruebas y entrega/despliegue de software.
CISO	Chief Information Security Officer	Responsable máximo de la función de seguridad de la información y ciberseguridad.
CMDB	Configuration Management Database	Base de datos de activos, elementos de configuración y relaciones técnicas.
CSF	Cybersecurity Framework	Marco de ciberseguridad de NIST utilizado para organizar capacidades de gobierno y gestión del riesgo.
CSPM	Cloud Security Posture Management	Gestión continua de configuraciones y postura de seguridad en entornos cloud.
CVE	Common Vulnerabilities and Exposures	Identificador público normalizado de vulnerabilidades conocidas.
CVSS	Common Vulnerability Scoring System	Sistema de puntuación de severidad técnica de vulnerabilidades; no equivale por sí solo al riesgo empresarial.
DAST	Dynamic Application Security Testing	Pruebas dinámicas de seguridad ejecutadas contra una aplicación en funcionamiento.
DKIM	DomainKeys Identified Mail	Mecanismo criptográfico para validar la autenticidad e integridad de mensajes de correo.
DLP	Data Loss Prevention	Controles para prevenir o detectar salida, exposición o uso no autorizado de información sensible.
DMARC	Domain-based Message Authentication, Reporting and Conformance	Política de autenticación y tratamiento de correo basada en SPF y DKIM.
DMZ	Demilitarized Zone	Zona de red separada para sistemas expuestos o con distinto nivel de confianza.
DNS	Domain Name System	Sistema de resolución de nombres utilizado para localizar servicios y recursos de red.
DPO	Data Protection Officer	Delegado de Protección de Datos; función responsable de supervisar obligaciones de privacidad cuando aplica.

Sigla / abreviatura	Significado	Uso / explicación en GalileoTechSolutions
EDR	Endpoint Detection and Response	Tecnología de monitorización, detección, investigación y respuesta en endpoints.
ENISA	European Union Agency for Cybersecurity	Agencia de la Unión Europea para la Ciberseguridad; aporta contexto de amenazas y buenas prácticas.
ENS	Esquema Nacional de Seguridad	Marco español de seguridad para sistemas del sector público y entidades dentro de su ámbito.
EOL	End of Life	Fin de vida de un producto o versión; puede implicar ausencia de mantenimiento.
EOS	End of Support	Fin del soporte del fabricante para un producto o versión.
ERP	Enterprise Resource Planning	Sistema de gestión empresarial integrado, por ejemplo finanzas, compras o gestión administrativa.
FIDO2	Fast Identity Online 2	Estándar de autenticación fuerte resistente a phishing mediante claves de seguridad o passkeys.
FIM	File Integrity Monitoring	Monitorización de integridad de archivos y configuraciones para detectar cambios no autorizados.
GPO	Group Policy Object	Objeto de directiva de grupo utilizado para aplicar configuración centralizada en entornos Microsoft.
HIDS	Host-based Intrusion Detection System	IDS instalado o ejecutado en un host para detectar actividad sospechosa local.
IAM	Identity and Access Management	Gestión de identidades, autenticación, autorización y ciclo de vida de accesos.
ID	Identifier / Identificador	Código utilizado para identificar de forma única un control, riesgo, registro o elemento.
IDS	Intrusion Detection System	Sistema que detecta actividad potencialmente maliciosa y genera alertas sin bloquear necesariamente el tráfico.
IEC	International Electrotechnical Commission	Organización internacional de normalización que participa en estándares ISO/IEC.
IPS	Intrusion Prevention System	Sistema de prevención de intrusiones capaz de bloquear tráfico malicioso en línea conforme a reglas.
ISO	International Organization for Standardization	Organización internacional de normalización.
IT	Information Technology	Función y tecnologías de sistemas de información; equivalente a TI en español.
JIT	Just-In-Time	Asignación temporal de privilegios o accesos únicamente durante el tiempo necesario.
JML	Joiner-Mover-Leaver	Proceso de altas, cambios y bajas de personas y sus accesos.
KPI	Key Performance Indicator	Indicador clave de rendimiento que mide cumplimiento o eficacia de un objetivo.
KRI	Key Risk Indicator	Indicador clave de riesgo que alerta sobre aumento de exposición o deterioro de la postura de seguridad.
LOPDGDD	Ley Orgánica de Protección de Datos Personales y garantía de los derechos digitales	Norma española que complementa el RGPD.
MAGERIT	Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información	Metodología española utilizada para estructurar el análisis y tratamiento del riesgo.
MDM	Mobile Device Management	Gestión centralizada de dispositivos, configuración, cumplimiento y políticas de seguridad.

Sigla / abreviatura	Significado	Uso / explicación en GalileoTechSolutions
MFA	Multi-Factor Authentication	Autenticación mediante dos o más factores independientes.
MITRE	MITRE Corporation	Organización que mantiene, entre otros recursos, la base de conocimiento MITRE ATT&CK; el nombre MITRE se trata como denominación propia.
MITRE ATT&CK	MITRE ATT&CK Enterprise	Base de conocimiento utilizada para describir tácticas y técnicas del adversario y orientar detecciones.
MTTD	Mean Time To Detect	Tiempo medio transcurrido hasta detectar un incidente o actividad maliciosa.
MTTR	Mean Time To Remediate / Recover	Tiempo medio de remediación o recuperación; el contexto del KPI determina cuál de los dos sentidos se utiliza.
Nº	Número	Abreviatura utilizada en métricas y tablas para expresar un recuento o cantidad de elementos.
NDR	Network Detection and Response	Tecnología de detección e investigación basada en telemetría de red.
NGFW	Next-Generation Firewall	Firewall de nueva generación con capacidades adicionales de inspección, aplicación y prevención.
NIDS	Network Intrusion Detection System	IDS de red que analiza tráfico para detectar patrones o comportamientos sospechosos.
NIPS	Network Intrusion Prevention System	IPS de red que inspecciona tráfico inline y puede bloquearlo.
NIS2	Network and Information Security Directive 2	Directiva europea sobre medidas para un alto nivel común de ciberseguridad.
NIST	National Institute of Standards and Technology	Organismo estadounidense que publica marcos, guías y estándares técnicos ampliamente utilizados.
NVD	National Vulnerability Database	Base de datos de vulnerabilidades mantenida por NIST.
OpenVAS	Open Vulnerability Assessment System	Escáner de vulnerabilidades utilizado para identificar exposición y vulnerabilidades conocidas; los resultados requieren validación y contexto de riesgo.
OWASP	Open Worldwide Application Security Project	Comunidad y fundación que publica guías y estándares de seguridad de aplicaciones.
PAM	Privileged Access Management	Gestión, control y monitorización de accesos privilegiados.
PST	Puesto de Trabajo (prefijo interno)	Prefijo usado en el Plan para identificar controles de la baseline corporativa del puesto de trabajo, por ejemplo PST-01.
RACI	Responsible, Accountable, Consulted, Informed	Matriz para asignar quién ejecuta, aprueba, es consultado o informado en cada actividad.
RBAC	Role-Based Access Control	Modelo de control de acceso basado en roles.
RD	Real Decreto	Tipo de norma jurídica española; en el Plan se usa para el RD 311/2022 del ENS.
Rev.	Revision (revisión)	Identifica la revisión de una publicación o documento, por ejemplo NIST SP 800-61 Rev. 3.
RGPD	Reglamento General de Protección de Datos	Reglamento europeo de protección de datos personales.
RPO	Recovery Point Objective	Máxima pérdida de datos tolerable medida como punto temporal de recuperación.
RRHH	Recursos Humanos	Función corporativa de gestión de personas.
RTO	Recovery Time Objective	Tiempo objetivo máximo para recuperar un servicio o proceso.

Sigla / abreviatura	Significado	Uso / explicación en GalileoTechSolutions
SaaS	Software as a Service	Software consumido como servicio cloud gestionado por un proveedor.
SAMM	Software Assurance Maturity Model	Modelo OWASP para evaluar y mejorar la madurez de seguridad del desarrollo de software.
SAST	Static Application Security Testing	Análisis estático de código o binarios para detectar debilidades sin ejecutar la aplicación.
SBOM	Software Bill of Materials	Inventario estructurado de componentes y dependencias de un producto software.
SCA	Software Composition Analysis	Análisis de dependencias y componentes de terceros para identificar riesgos y vulnerabilidades.
SDLC	Software Development Life Cycle	Ciclo de vida de desarrollo de software.
SGSI	Sistema de Gestión de Seguridad de la Información	Sistema de gestión para gobernar riesgos, políticas, controles y mejora continua.
SIEM	Security Information and Event Management	Plataforma que centraliza, normaliza y correlaciona eventos y logs para generar alertas y apoyar investigación y auditoría.
SLA	Service Level Agreement	Acuerdo u objetivo de nivel de servicio, por ejemplo plazo máximo de remediación o atención.
SOC	Security Operations Center	Función/equipo encargado de la monitorización, triaje, investigación y escalado de alertas de seguridad.
SP	Special Publication	Serie de publicaciones técnicas de NIST, como NIST SP 800-61.
SPF	Sender Policy Framework	Mecanismo de correo que declara qué servidores están autorizados a enviar mensajes para un dominio.
SSDLC	Secure Software Development Life Cycle	Ciclo de desarrollo de software que integra seguridad de forma sistemática en todas las fases.
SSH	Secure Shell	Protocolo cifrado de acceso remoto y administración de sistemas.
SSO	Single Sign-On	Inicio de sesión único para acceder a múltiples servicios mediante una identidad central.
TI	Tecnologías de la Información	Equivalente en español de IT; comprende sistemas, infraestructura, aplicaciones y servicios tecnológicos.
TLS	Transport Layer Security	Protocolo criptográfico para proteger comunicaciones en tránsito.
USB	Universal Serial Bus	Interfaz para conexión de periféricos y soportes extraíbles.
VPN	Virtual Private Network	Canal cifrado para acceso remoto o conexión segura entre redes.
WAF	Web Application Firewall	Firewall especializado en proteger aplicaciones web frente a tráfico malicioso.
XDR	Extended Detection and Response	Plataforma que correlaciona telemetría de varias capas para detección y respuesta.
ZTNA	Zero Trust Network Access	Acceso a recursos basado en identidad, postura y contexto siguiendo principios Zero Trust.

APROBACIÓN Y COMPROMISO

La Dirección de GalileoTechSolutions declara que la ciberseguridad constituye un riesgo empresarial y se compromete a proporcionar autoridad, recursos y seguimiento para la aplicación de este Plan, incluida la capacidad de prevención, detección, monitorización y respuesta sustentada por IDS/IPS, SIEM, EDR/XDR y el SOC. Todos los miembros de la organización y terceros dentro de su alcance deben cumplir las políticas y procedimientos derivados.

Rol	Firma	Fecha
Dirección General		

Rol	Firma	Fecha
CISO / Responsable de Seguridad	_____	_____
DPO / Legal	_____	_____